

Implementación de Cuentas dMSA (Delegated Managed Service Accounts) en Windows Server 2025

Autor: SYSARMOR TECH

Enfoque: Infraestructura, Operación, Seguridad e Innovación

Introducción — El problema real

- ✓ Cuentas de Usuario Tradicionales: Vulnerables a Kerberoasting y AS-REP Roasting por contraseñas estáticas.
- ✓ gMSA (Windows Server 2012): Rotación automática asignada a grupos de equipos.
- ✓ dMSA (Windows Server 2025): Asignación 1:1 vinculada a la credencial del hardware del dispositivo local.

1. Contexto y Evolución de Cuentas de Servicio

Cuenta MSA

Las cuentas MSA (Managed Service Account), o cuentas de servicio administradas, se crearon como un tipo de cuenta que permite a los administradores Y a sus organizaciones administrar automáticamente los derechos Y permisos de los servicios informáticos (con contraseñas), en resumen, una cuenta de usuario que los servicios de Windows utilizan para iniciar sesión en un equipo o un dominio con un conjunto específico de derechos y permisos.

Cuenta gMSA

Las cuentas gMSA (*Group Managed Service Account* o cuenta de servicio administrada de grupo) es un tipo especial de cuenta de dominio en Active Directory. Su función principal es proporcionar una identidad digital segura para ejecutar servicios y aplicaciones en uno o varios servidores de forma simultánea, eliminando la necesidad de cambiar contraseñas de forma manual.

Cuenta dMSA

Las cuentas dMSA (*Delegated Managed Service Account* o Cuenta de Servicio Administrada Delegada) es un tipo de cuenta de Active Directory en Windows Server (disponible desde la versión 2025). Sirve para ejecutar aplicaciones o servicios en un servidor específico de forma segura, ya que el sistema rota y administra las contraseñas de manera automática

2. Diferencias clave: MSA vs. gMSA vs. dMSA

Este cuadro es el resumen de las diferencias y la evolución de las cuentas de servicio.



3. Requisitos previos

Controlador de Dominio en Windows Server 2025: Requerido para procesar las solicitudes. dMSA introduce la clase msDS-DelegatedManagedServiceAccount en el esquema de WS2025.

Nota de arquitectura: No es estrictamente obligatorio elevar el Forest Functional Level a 2025 en entornos híbridos, siempre que el esquema esté actualizado (adprep /forestprep) y los DCs correspondientes ejecuten WS2025.

- Clave Raíz KDS activa: Configurada en Active Directory mediante Add-KdsRootKey.
- Módulo de PowerShell de Active Directory / RSAT: Correspondiente a Windows Server 2025.
- Privilegios: Credenciales con permisos de Domain Admin.
- Credential Guard: Requerido en el equipo destino si se va a realizar migración de cuentas existentes.

4. Creación y validación de cuenta de servicio clásica (previa a dMSA)

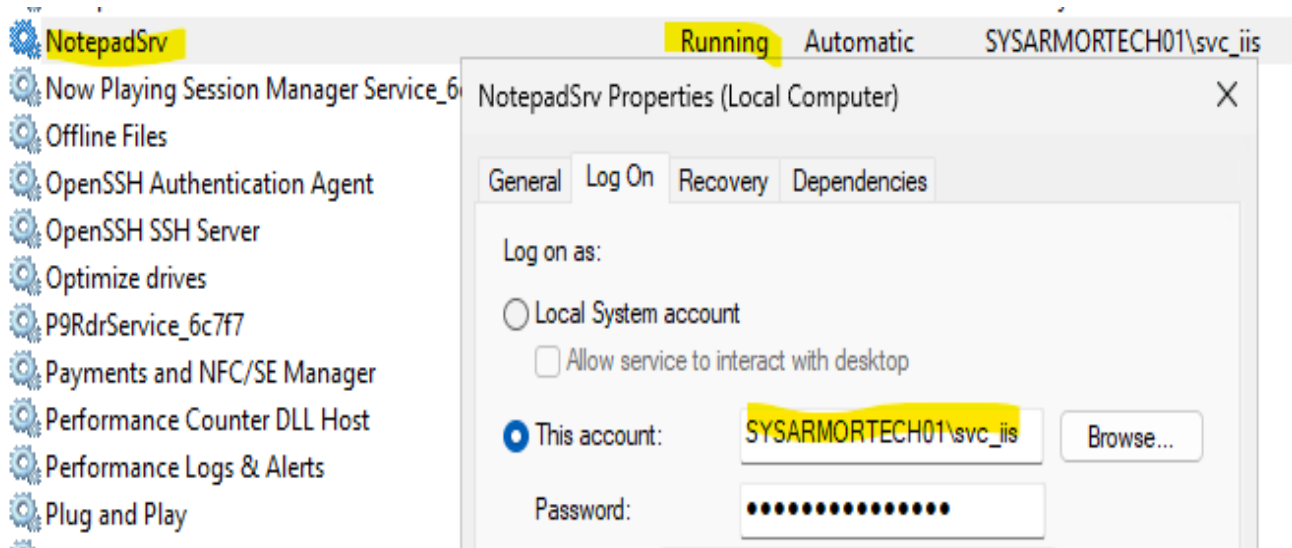
Para contrastar el comportamiento frente a dMSA, se crea primero una cuenta de servicio clásica desde un Controlador de Dominio con privilegios de Domain Admin:

```
New-ADUser -Name "svc_iis" -SamAccountName "svc_iis" -AccountPassword  
(Read-Host -AsSecureString "Ingrese contraseña") -Enabled $true -  
PasswordNeverExpires $true -Path "OU=Usuarios,DC=SysArmorTech,DC=com"
```

Validamos su creación en el Active Directory Users and computers

Prueba de concepto con servicio local (NotepadSrv en EQUIPO10)

1. En el servidor EQUIPO10, se asigna el derecho de Log on as a service (secpol.msc) a la cuenta SYSARMORTECH01\svc_iis para evitar el error 1297.
2. Se configura el servicio NotepadSrv para iniciar sesión con la cuenta creada.



5. Como es el proceso de crear una cuenta DMSA

A diferencia de las gMSA (que permiten definir grupos de seguridad con múltiples equipos), las cuentas dMSA exigen asociar explícitamente la cuenta a la identidad de un servidor específico.

Paso 1: Crear el objeto dMSA con cifrado estricto (AES128, AES256)

Ejecutar en PowerShell con el módulo de Active Directory de Windows Server 2025:

```
New-ADServiceAccount -CreateDelegatedServiceAccount -Name  
"iis_service_lab" -DNSHostName "iis_service_lab.SysArmorTech.com" -  
KerberosEncryptionType AES128,AES256
```

Paso 2: Delegar el acceso de recuperación de credenciales a EQUIPO10

Asignar el servidor autorizado para recuperar la contraseña administrada:

```
Set-ADServiceAccount -Identity "iis_service_lab" -  
PrincipalsAllowedToRetrieveManagedPassword "EQUIPO10$"
```

Paso 3: Validar los atributos del objeto dMSA

Verificar la correcta configuración de los atributos en Active Directory:

```
Get-ADServiceAccount -Identity "iis_service_lab" -Properties *
```

Inspección de Atributos mediante ldp.exe

Para verificar la estructura interna del objeto en Active Directory mediante ldp.exe:

1. Conexión y Autenticación:

- Abrir ldp.exe (Win + R > ldp.exe).
- Ir a **Connection > Connect...** e ingresar el nombre del DC o puerto 389.
- Ir a **Connection > Bind...** y autenticarse con credenciales de *Domain Admin*.

2. Navegación en el Árbol del Dominio:

- Seleccionar **View > Tree** y establecer el BaseDN (DC=SysArmorTech,DC=com).
- Desplegar el contenedor por defecto: CN=Managed Service Accounts,DC=SysArmorTech,DC=com.
- Seleccionar el objeto creado (CN=iis_service_lab).

Atributos clave de dMSA

- **ObjectClass:** Identifica la clase ms-DS-Delegated-Managed-Service-Account.
- **SamAccountName:** Finaliza con el carácter \$ (iis_service_lab\$).
- **DelegatedMSAState:** El valor {0} indica el estado inicial (unbound) previo a la primera vinculación del host autorizado (EQUIPO10\$).

- **PrincipalsAllowedToRetrieveManagedPassword:** Muestra la lista explícita de equipos autorizados (CN=EQUIPO10...).
- **ManagedPasswordIntervalInDays:** Define el intervalo de rotación automática (30 días por defecto).
- **KerberosEncryptionType:** Confirma el uso de algoritmos robustos (AES128, AES256).

The screenshot shows the Active Directory Users and Groups console for the domain 'SysArmorTech,DC=com'. The left pane displays the directory tree, with 'CN=iis_service_lab,CN=Managed Service Accounts,DC=SysArmorTech,DC=com' selected. The right pane shows the properties for this account.

Getting 1 entries:
Dn: CN=iis_service_lab,CN=Managed Service Accounts,DC=SysArmorTech,DC=com

accountExpires: 9223372036854775807 (never);
 badPasswordTime: 0 (never);
 badPwdCount: 0;
 cn: iis_service_lab;
 codePage: 0;
 countryCode: 0;
 distinguishedName: CN=iis_service_lab,CN=Managed Service Accounts,DC=SysArmorTech,DC=com;
 dnsHostName: iis_service.SysArmorTech.com;
 dSCorePropagationData: 0x0 = ();
 instanceType: 0x4 = (WRITE);
 isCriticalSystemObject: FALSE;
 lastLogoff: 0 (never);
 lastLogon: 0 (never);
 localPolicyFlags: 0;
 logonCount: 0;
 msDS-DelegatedMSAState: 0;
 msDS-GroupMSAMembership: <ldap: Binary blob 80 bytes>;
 msDS-ManagedPasswordId: <ldap: Binary blob 120 bytes>;
 msDS-ManagedPasswordInterval: 30;
 msDS-SupportedEncryptionTypes: 0x18 = (AES128_CTS_HMAC_SHA1_96 | AES256_CTS_HMAC_SHA1_96);
 name: iis_service_lab\$;
 objectCategory: CN=ms-DS-Delegated-Managed-Service-Account,CN=Schema,CN=Configuration,DC=SysArmorTech,DC=com;
 objectClass: (6): top; person; organizationalPerson; user; computer; msDS-DelegatedManagedServiceAccount;
 objectGUID: f25125c1-bb15-44cc-89ec-a2d3829d8436;
 objectSid: S-1-5-21-1478490303-3292442971-188057600-1112;
 primaryGroupID: 515 = (GROUP_RID_COMPUTERS);
 pwdLastSet: 17/08/2026 8:09:34 a. m. SA Pacific Standard Time;
 sAMAccountName: iis_service_lab\$;
 sAMAccountType: 805306369 = (MACHINE_ACCOUNT);
 userAccountControl: 0x1000 = (WORKSTATION_TRUST_ACCOUNT);
 uSNCreated: 16855;
 uSNChanged: 16855;
 whenChanged: 17/08/2026 8:09:34 a. m. SA Pacific Standard Time;
 whenCreated: 17/08/2026 8:09:34 a. m. SA Pacific Standard Time;

Registro de la cuenta iis_service_lab en equipo10

Install-ADServiceAccount -Identity "iis_service_lab"

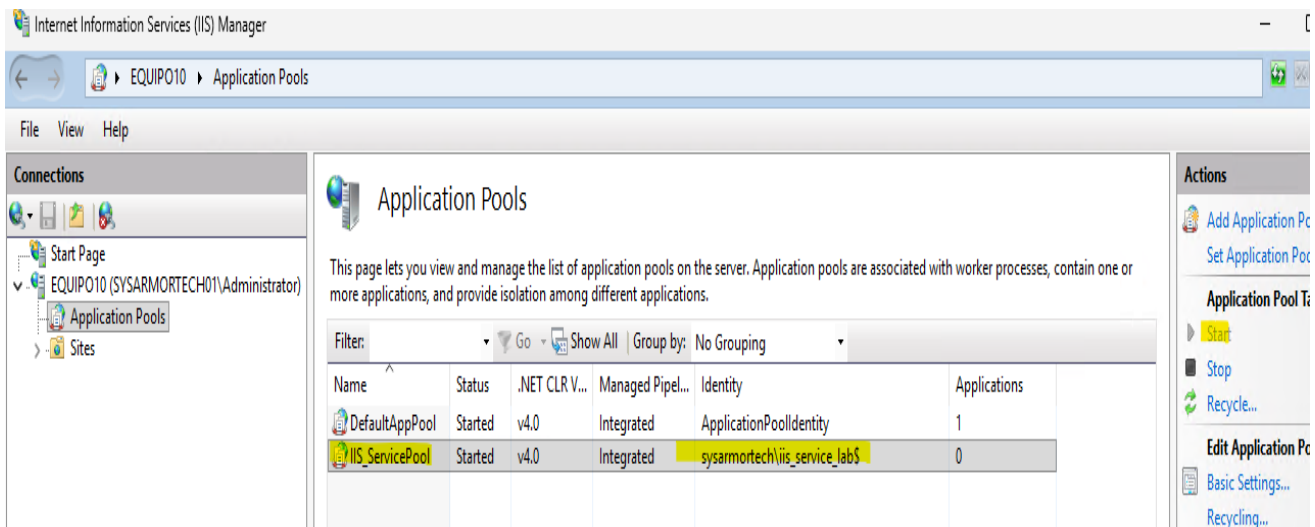
Test-ADServiceAccount -Identity "iis_service_lab"

Implementación en IIS (Application Pool en EQUIPO10)

Para utilizar la cuenta dMSA en un *Application Pool* de Internet Information Services (IIS) en EQUIPO10:

1. Abrir **IIS Manager** en EQUIPO10.
2. Ir a **Application Pools** > Seleccionar IIS_ServicePool > **Advanced Settings**.
3. En el campo **Identity**, seleccionar **Custom Account** e ingresar:
 - **User name:** SYSARMORTECH\iis_service_lab\$ (Es indispensable incluir el sufijo \$).
 - **Password:** Dejar en blanco.

4. Iniciar o reiniciar el *Application Pool*. Si el estado cambia a **Started** sin solicitar contraseña manual, la dMSA está operando correctamente y la credencial ha sido delegada al host.



Anexo los comandos en PowerShell sobre cómo se podría automatizar el proceso de asignación de una cuenta de este tipo en un Application Pool, para evitar errores mecánicos que se puedan cometer desde la consola gráfica de IIS:

Import-Module WebAdministration

```
Set-ItemProperty -Path "IIS:\AppPools\IIS_ServicePool" -Name  
"processModel.identityType" -Value 3
```

```
Set-ItemProperty -Path "IIS:\AppPools\IIS_ServicePool" -Name  
"processModel.userName" -Value "SYSARMORTECH\iis_service_lab$"
```

```
Set-ItemProperty -Path "IIS:\AppPools\IIS_ServicePool" -Name  
"processModel.password" -Value ""
```

```
Restart-WebAppPool -Name "IIS_ServicePool"
```

6. Casos de Uso Reales & Hardening

- **Servicios críticos e IIS:** Eliminación de contraseñas locales almacenadas en texto plano o registros de configuración.
- **Tareas Programadas (Scheduled Tasks):** Permite ejecutar procesos desatendidos sin riesgo de exposición de credenciales en la memoria local o scripts.
- **Reducción de Superficie de Ataque:** Mitiga vectores de Kerberoasting al forzar cifrado AES y eliminar contraseñas estáticas asignadas a usuarios.

7. Consideraciones y limitaciones

- **Soporte exclusivo:** Las dMSA requieren que el host ejecute Windows Server 2025.
- **Delegación No Restringida:** La delegación no restringida de Kerberos deja de funcionar tras completar la migración si la cuenta de origen dependía de ella.
- **Entornos RODC:** Los Controladores de Dominio de Solo Lectura requieren pasos manuales adicionales para el almacenamiento en caché de credenciales.

8. Conclusión técnica

La implementación de **dMSA en Windows Server 2025** representa un avance fundamental en el *hardening* de infraestructura Active Directory. Al eliminar las contraseñas estáticas y vincular la identidad del servicio directamente al hardware del servidor autorizado, se logra neutralizar las técnicas tradicionales de extracción de credenciales, elevando la postura de seguridad operacional en el entorno empresarial.

*En **SysArmor Tech**, esta guía y su implementación se construyen bajo principios de arquitectura robusta, automatización y seguridad por diseño. Cada laboratorio busca resolver problemáticas complejas de infraestructura de nivel 2 y 3, priorizando el uso de estándares limpios y mantenibles.*

Al tratarse de un espacio de divulgación e ingeniería personal, este documento se comparte como un recurso de referencia técnica abierta. Te invito a explorar los demás artículos del sitio, utilizar las herramientas interactivas disponibles y conectar a nivel profesional a través de LinkedIn.